

MODULE 4: INDUSTRY STANDARDS

PROJECT TASK 3: FRAMEWORK SELECTION & CONTROL MAPPING

COURSE: Cybersecurity Legislation and Compliance Assessments

MODULE: 4 – Industry Standards & Technical Control Mapping

STUDENT: HASSANI Mohammad Salem

DATE: January 17, 2026

INSTRUCTOR: Asen Grozdanov

PART 1: FRAMEWORK SELECTION STRATEGY

FRAMEWORK SELECTION MEMO

TO: NorthStream Technologies Chief Information Security Officer (CISO)

FROM: Cybersecurity Compliance Assessment Team

DATE: January 17, 2026

RE: FRAMEWORK SELECTION MEMO – NIST CSF 2.0 vs ISO/IEC 27001

EXECUTIVE SUMMARY

This memo evaluates two industry-leading cybersecurity frameworks for NorthStream's compliance and security program. After analysis of NorthStream's organizational profile (Canadian-based, international data flows, cloud infrastructure), we recommend **NIST Cybersecurity Framework 2.0 (NIST CSF)** as the primary governance structure for the following 18 months, with phased migration toward ISO/IEC 27001 certification as a secondary objective in Year 2.

FRAMEWORK COMPARISON

NIST Cybersecurity Framework 2.0 (NIST CSF)

Aspect	Details
Origin	National Institute of Standards and Technology (U.S. federal agency)
Architecture	6 Functions (Govern, Identify, Protect, Detect, Respond, Recover); 23 Categories; 210+ Subcategories

Cost	FREE – no licensing, no certification costs
Implementation	Flexible, voluntary adoption; iterative maturity approach
Flexibility	High – prescriptive goals, flexible methods
Audit/Certification	Not required (optional third-party assessment: CAD \$10K–30K)
Time to Implement	6–24 months (phased)

ISO/IEC 27001 (Information Security Management Systems)

Aspect	Details
Origin	International Organization for Standardization
Architecture	14 Control Categories; 114 controls
Cost	CAD \$300 standard + CAD \$40K–80K certification audit
Implementation	Prescriptive and structured ISMS
Flexibility	Low – controls must be implemented as specified
Audit/Certification	MANDATORY (CAD \$15K–25K annual surveillance)
Time to Implement	12–18 months (compressed)

COMPARATIVE ANALYSIS

Factor	NIST CSF 2.0	ISO/IEC 27001
Cost (Year 1)	\$0	\$80K–100K
Ongoing Cost (Annual)	\$0–30K	\$25K–40K
Implementation Timeline	6–24 months	12–18 months
Flexibility	High	Low
Certification Required	No	YES
Best For	Organizations building programs from scratch	Organizations requiring third-party certification

RECOMMENDATION: NIST CYBERSECURITY FRAMEWORK 2.0

Selected Framework: NIST CSF 2.0

Justification:

1. **Cost Efficiency:** NIST CSF's \$0 cost vs ISO's \$100K+ Year 1 investment makes NIST pragmatic for 18-month Phase 1. Cost saved (~CAD \$100K) can be redirected to technical control implementation.
2. **Regulatory Alignment:** NIST CSF maps directly to legal requirements:
 - PIPEDA Principle 4.7 → NIST CSF PR.DS-01 (Data at Rest Protection)
 - GDPR Article 32 → NIST CSF PR.DS-02 (Data in Transit Protection)
 - GDPR Article 33 → NIST CSF DE.DP-01 & RS.RP-01 (Incidents & Response)
3. **Organizational Maturity:** NIST CSF's iterative approach allows NorthStream to achieve phased maturity without "all-or-nothing" certification pressure.
4. **Cloud Infrastructure Context:** NorthStream uses AWS (us-east region) for EU backup. NIST CSF explicitly addresses:
 - PR.DS-01 (Data at Rest – cloud encryption)
 - DE.CM-01 (Cloud monitoring)
 - CP.BP-01 (Backup/recovery)
5. **International Expansion Path:** If EU expansion occurs, company can migrate to ISO 27001 in Year 2 (NIST → ISO transition is standard path).

IMPLEMENTATION TIMELINE

Months 1–3:

- Governance setup (CISO establishes Cybersecurity Steering Committee)
- NIST CSF 2.0 training for IT/security teams
- Current-state assessment (baseline maturity: Level 1–2)

Months 4–9:

- Implement Protect & Identify controls
 - Encryption at rest/transit (PR.DS-01, PR.DS-02)
 - Access management (PR.AC-01, PR.AC-02)
 - Data inventory & classification (ID.AM-01)

Months 10–15:

- Implement Detect & Respond functions
 - Incident detection systems (DE.DP-01, DE.CM-01)
 - Breach notification procedures (RS.RP-01)

Months 16–18:

- Document governance & recovery controls
- Third-party NIST CSF assessment (optional: CAD \$20K)
- Prepare ISO 27001 transition roadmap (Year 2)

ESTIMATED YEAR 1 BUDGET

Item	Cost
NIST CSF training & consulting	CAD \$15K–25K
Encryption tools (data at rest)	CAD \$30K–50K
Access management system (IAM)	CAD \$40K–60K
Incident detection/monitoring	CAD \$25K–40K
Breach notification platform	CAD \$10K–15K
Staff training & documentation	CAD \$10K
Optional: Third-party assessment	CAD \$20K
TOTAL YEAR 1	CAD \$150K–225K

CONCLUSION

NIST Cybersecurity Framework 2.0 is the optimal choice for NorthStream Phase 1 (2026–2027) because it provides:

- Zero licensing cost with full regulatory alignment
- Flexibility to implement iteratively
- Direct mapping to PIPEDA, GDPR, and Quebec Law 25
- Clear path to ISO 27001 certification in Year 2

Proceed with NIST CSF 2.0 implementation starting February 2026.

PART 2: COMPLIANCE MAPPING MATRIX

LEGAL-TO-TECHNICAL CONTROL MAPPING

Based on legal requirements identified in Project Task 1 (Labs 1 & 2), the following five mappings translate legal obligations into actionable technical controls within NIST Cybersecurity Framework 2.0.

MAPPING 1: GDPR ARTICLE 32 – ENCRYPTION REQUIREMENT

Source Law/Regulation:

GDPR Article 32 – Technical and Organizational Measures

Legal Requirement Text:

"The controller and processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including as appropriate: (a) the pseudonymization and encryption of personal data..."

Applicable to NorthStream:

EU customer data (150 customers in France, Germany, Netherlands) stored in AWS us-east-1 backup requires GDPR Article 32 compliance. Currently, NorthStream backups use AWS-managed keys (shared key model), not customer-controlled encryption.

Chosen Framework ID:

NIST CSF 2.0 – **PR.DS-01** (Data-at-Rest is Protected)

NIST CSF Control Description:

"Data at rest is protected. (Example Practices: Encrypt sensitive data at rest; ensure encryption keys are protected and escrowed; apply appropriate data minimization strategies; support recovery from ransomware attacks.)"

NorthStream Gap:

NorthStream currently relies on AWS Server-Side Encryption (SSE-S3) with AWS-managed keys. GDPR best practice recommends customer-managed encryption keys (CMK). NorthStream must implement AWS Key Management Service (KMS) with NorthStream-controlled Customer Master Keys.

Rationalization:

Implementing NIST PR.DS-01 with AWS KMS CMK encryption directly satisfies GDPR Article 32's encryption requirement. Customer-managed keys address Schrems II concerns regarding U.S. government surveillance. This control ensures EU customer data remains encrypted even if AWS infrastructure is breached.

Implementation Details:

- Enable AWS KMS encryption for all S3 buckets containing EU customer data
 - Configure KMS CMK with annual key rotation
 - Restrict KMS key access to NorthStream security team only
 - Enable AWS CloudTrail logging of all KMS key usage
 - Document encryption settings in NIST PR.DS-01 control evidence
 - **Cost:** CAD \$5K–10K
 - **Timeline:** 4–6 weeks
-

MAPPING 2: PIPEDA PRINCIPLE 4.7 – SAFEGUARDS & DATA SECURITY

Source Law/Regulation:

PIPEDA Principle 4.7 – Safeguards

Legal Requirement Text:

"Organizations shall protect personal information by making reasonable efforts to establish and maintain appropriate physical, administrative and technological safeguards against such risks as unauthorized access, disclosure, modification or destruction."

Applicable to NorthStream:

Employee records (1,200 staff) stored in Calgary HR system contain Social Insurance Numbers (SIN), banking information, and health benefits claims. Under PIPEDA and Quebec Law 25, these require "appropriate" safeguards.

Chosen Framework ID:

NIST CSF 2.0 – **PR.AC-01** & **PR.AC-02** (Access Control)

NIST CSF Control Description:

"PR.AC-01: Processes and procedures are maintained to manage identification, authentication, and authorization. PR.AC-02: Physical and logical access to information assets is managed and controlled, incorporating least privilege and segregation of duties."

NorthStream Gap:

NorthStream HR system has no role-based access control (RBAC). Payroll clerk can view health benefits; benefits analyst can access banking details. No audit log of access attempts. This violates PIPEDA Principle 4.7 and Quebec Law 25 Article 18.

Rationalization:

Implementing NIST PR.AC-01 & PR.AC-02 satisfies PIPEDA's "appropriate safeguards" requirement by establishing least-privilege access. PR.AC-02 requirement for "monitoring" is satisfied by database activity monitoring (DAM).

Implementation Details:

- Deploy role-based access control (RBAC):
 - Payroll Role: SIN, banking, salary history only
 - HR Admin Role: Name, email, department, hire date, job title only
 - Benefits Role: Health plan elections, claims history only
 - Privacy Officer Role: Full employee record access (with audit logging)
 - Implement database activity monitoring (DAM) tool (e.g., Imperva, Redgate)
 - Enforce multi-factor authentication (MFA) for all HR system access
 - Conduct quarterly access reviews
 - **Cost:** CAD \$40K–60K
 - **Timeline:** 8–12 weeks
-

MAPPING 3: QUEBEC LAW 25 ARTICLE 13 – EXPLICIT CONSENT FOR SENSITIVE DATA

Source Law/Regulation:

Quebec Law 25, Article 13

Legal Requirement Text:

"Express consent must be obtained before collection, use or disclosure of sensitive personal information, including precise location data, biometric data, health information, and sexual orientation. Consent must be freely given, specific, and informed, with no pre-checked mechanisms."

Applicable to NorthStream:

NorthStream Rewards mobile app collects GPS location data (precise location coordinates updated every 5 minutes during driver activity). Current app presents bundled consent ("NorthStream needs permission to access location, contacts, and photos"). This violates Article 13 (not "specific" to location).

Chosen Framework ID:

NIST CSF 2.0 – **ID.BE-01** & **PR.AT-01** (Data Governance & Training)

NIST CSF Control Description:

"ID.BE-01: Risk management strategy is established and communicated. PR.AT-01: All staff are informed and trained regarding organizational security policies relevant to their job function."

NorthStream Gap:

NorthStream lacks documented data governance policy specifying which data requires express consent under Law 25. GPS location is collected with bundled consent (not separate). In-app consent mechanism lacks timestamp/audit trail.

Rationalization:

Implementing NIST ID.BE-01 establishes a documented data governance policy clarifying that GPS location requires separate express consent with timestamp. PR.AT-01 ensures staff understand Law 25 requirements.

Implementation Details:

- Develop Quebec Law 25 Data Governance Policy specifying:
 - Location data: Requires SEPARATE express consent (unchecked by default)
 - Consent documentation: Mobile app logs consent grant timestamp
 - Consent withdrawal: In-app toggle to disable location
- Update privacy policy with Law 25 Article 13 compliant language
- Implement in-app consent logging:
 - Firebase Events or custom analytics log location consent
 - Store consent records in encrypted database (60-month retention)
 - Allow users to export consent history
- Train mobile development team on Law 25 Article 13

- **Cost:** CAD \$15K–25K
- **Timeline:** 6–8 weeks

MAPPING 4: GDPR ARTICLE 33 – MANDATORY BREACH NOTIFICATION (72 HOURS)

Source Law/Regulation:

GDPR Article 33 – Notification of a Personal Data Breach to the Supervisory Authority

Legal Requirement Text:

"In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of the personal data breach, notify the breach to the supervisory authority unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons."

Applicable to NorthStream:

If EU customer data (150 customers in France, Germany, Netherlands) is breached, NorthStream must notify French CNIL, German BfDI, and Dutch AP within 72 hours. GDPR makes notification MANDATORY (unlike PIPEDA's risk-based approach).

Chosen Framework ID:

NIST CSF 2.0 – **RS.RP-01** & **DE.DP-01** (Response Planning & Incident Detection)

NIST CSF Control Description:

"RS.RP-01: Response processes and procedures are executed to ensure response to detected cybersecurity incidents. DE.DP-01: Incidents are detected and categorized to determine severity level."

NorthStream Gap:

NorthStream has basic incident response plan but does NOT explicitly address:

- 72-hour GDPR notification timeline
- Identification of incidents involving EU customer data
- Template letters for EU DPA notifications
- Communication flow with legal counsel and DPO

Rationalization:

Implementing NIST RS.RP-01 & DE.DP-01 translates GDPR Article 33's mandatory 72-hour requirement into operational procedures. RS.RP-01 requires breach notification timelines and regulatory contacts. DE.DP-01 requires incident categorization (e.g., "Involves EU customer data?").

Implementation Details:

- Revise Incident Response Plan to include GDPR-specific procedures:
 - Define "breach discovery" moment (when unauthorized access first detected)
 - Establish timeline: Hour 0 (detection) → Hour 1 (CISO notification) → Hour 24 (assessment) → Hour 48 (DPO review) → Hour 72 (submit to EU DPA)
 - Create incident categorization matrix:

- Category A: Involves EU customer data → 72-hour GDPR notification
 - Category B: Involves Canadian customer data → Risk-based PIPEDA assessment
 - Category C: Involves employee data only → PIPEDA/Law 25 assessment
 - Document DPA contacts: France (CNIL), Germany (BfDI), Netherlands (AP)
 - Develop notification templates for each EU DPA
 - Establish incident response team:
 - CISO (incident commander)
 - DPO (GDPR compliance lead)
 - IT Security (technical investigation)
 - Legal counsel (notification language)
 - Communications (external notification)
 - Conduct quarterly tabletop exercises testing 72-hour timeline
 - **Cost:** CAD \$10K–15K
 - **Timeline:** 4–6 weeks
-

MAPPING 5: QUEBEC LAW 25 ARTICLES 14–18 – PRIVACY OFFICER & INFORMATION SECURITY PROGRAM

Source Law/Regulation:

Quebec Law 25, Articles 3–8 (Privacy Officer) & Articles 14–18 (Information Security)

Legal Requirement Text:

"Organizations collecting personal information of Quebec residents must: (1) Appoint a designated Privacy Officer responsible for compliance; (2) Establish and maintain an information security program proportionate to the sensitivity of personal information and risks of processing; (3) Conduct Privacy Impact Assessments before deploying new data processing systems; (4) Document information security policies; (5) Notify CAI of breaches within 24 hours of awareness."

Applicable to NorthStream:

NorthStream's Montreal-based Rewards Cloud infrastructure processes data for 40,000–50,000 Quebec customers and Quebec employees. Under Law 25, NorthStream MUST appoint Privacy Officer (failure = CAD \$100K penalty regardless of other compliance status).

Chosen Framework ID:

NIST CSF 2.0 – **GV.RK-01**, **GV.OC-01**, & **PR.OV-01** (Governance & Policies)

NIST CSF Control Description:

"GV.RK-01: Risk management strategy and approach are established. GV.OC-01: Organization understands its mission and stakeholder expectations. PR.OV-01: Organizational policies and procedures are documented and communicated."

NorthStream Gap:

- No appointed Privacy Officer
- No documented information security program for Law 25
- No Privacy Impact Assessment process
- Security policies exist but not formally registered with CAI

Rationalization:

Implementing NIST GV/PR controls translates Quebec Law 25's governance requirements into NIST framework. GV.OC-01 establishes Privacy Officer appointment. PR.OV-01 requires documented policies. Together, they address Law 25's structural requirements.

Implementation Details:

- **Appoint Privacy Officer:**
 - Full-time role recommended (CAD \$80K–120K annually)
 - Core responsibilities: Law 25/PIPEDA/GDPR compliance, subject access requests, breach management, regulatory liaison, PIA oversight
 - Qualifications: Law degree + CIPP/C certification + 3+ years experience
- **Develop Information Security Program (Law 25 Article 14–18):**
 - Document policies: Access control, data classification, encryption, incident response, breach notification (24-hour CAI deadline), data retention, vendor management, employee training
 - Register information security program with CAI
- **Establish Privacy Impact Assessment (PIA) Process:**
 - Before deploying new systems processing Quebec data, conduct PIA
 - PIA addresses: Necessity, legal basis, data categories, processing activities, recipients, risks & safeguards
 - Submit to Privacy Officer for approval; register with CAI if high-risk
 - Cost per PIA: CAD \$5K–10K
- **Implement 24-Hour Breach Notification:**
 - Upon breach discovery involving Quebec data, notify CAI within 24 hours
 - Maintain breach notification log for audit trail
- **Staff Training:**
 - New Privacy Officer: 40 hours on Law 25/PIPEDA/GDPR/PIA/breach procedures
 - All staff: 15-minute mandatory video on Law 25 basics + annual refresh
- **Cost:**
 - Privacy Officer: CAD \$80K–120K annually
 - Information security program: CAD \$15K–25K

- PIAs (annual): CAD \$20K–40K
 - Compliance management tool: CAD \$5K–10K
 - Training: CAD \$3K–5K
 - **Total Year 1:** CAD \$128K–215K
- **Timeline:**
 - Privacy Officer appointment: IMMEDIATE (within 30 days)
 - Information security program: 8–12 weeks
 - First PIA: 4–6 weeks
 - Breach notification procedure: 2–4 weeks

COMPLIANCE MAPPING SUMMARY

#	Source Law	NIST Framework ID	Requirement	Technical Control	Risk Level	Status
1	GDPR Article 32	PR.DS-01	Encrypt personal data at rest	AWS KMS CMK encryption for EU backup	HIGH	Not Implemented
2	PIPEDA Principle 4.7	PR.AC-01/02	Safeguards; access control	RBAC + DAM for HR system	HIGH	Partially Implemented
3	Quebec Law 25 Article 13	ID.BE-01/PR.AT-01	Explicit consent for sensitive data	Separate location consent + logging	HIGH	Not Implemented
4	GDPR Article 33	RS.RP-01/DE.DP-01	72-hour breach notification	IRP revision; DPA templates	CRITICAL	Partially Implemented
5	Quebec Law 25 Articles 14–18	GV.RK-01/GV.OC-01/PR.OV-01	Privacy Officer + info security program	Privacy Officer role + documentation	CRITICAL	Not Implemented

PART 3: IMPLEMENTATION RISK ANALYSIS

IMPLEMENTATION CHALLENGE ASSESSMENT

Selected for Analysis: Mapping 5 – Quebec Law 25 Article 14–18 (Privacy Officer & Information Security Program)

IDENTIFICATION: THE HARDEST CONTROL TO IMPLEMENT

After reviewing all five mappings, **Control 5 (Privacy Officer appointment & information security program)** presents the most significant implementation challenge for NorthStream. While Controls 1–4 are primarily TECHNICAL, Control 5 is fundamentally ORGANIZATIONAL and requires:

- Establishment of new governance function
- Structural changes to NorthStream's leadership
- Sustained resource allocation

WHY THIS CONTROL IS HARDEST

1. No Existing Organizational Role

NorthStream currently lacks a dedicated Privacy Officer. Unlike technical controls (encryption, access management) where IT has existing expertise, the Privacy Officer role is entirely new, requiring either:

- Hiring full-time employee (CAD \$80K–120K annually, 3–6 month recruitment)
- Engaging external consultant (CAD \$25K–35K annually, external dependency)

2. Dual Competency Requirement

Privacy Officer must understand BOTH legal/compliance AND technical systems, bridging legal, IT, operations, and business teams with:

- Law degree or privacy certification (CIPP/C)
- Cloud infrastructure understanding (AWS, databases)
- Change management skills
- This is a scarce skill set; recruitment time ~3–6 months

3. Cultural Resistance

Many NorthStream staff will view Privacy Officer role as "compliance burden." Without executive sponsorship (CISO + CFO), Privacy Officer will face:

- Pushback from product teams ("slowing feature releases")
- Lack of cooperation from IT staff
- Budget constraints ("why hire another role?")

4. Ongoing Commitment

Unlike one-time technical implementations, Privacy Officer requires continuous investment:

- Annual Privacy Impact Assessment cycle: CAD \$20K–40K
- Quarterly compliance reviews: CAD \$10K–15K
- Staff training & awareness: CAD \$5K–8K annually
- Regulatory liaison: Time/resource intensive
- Recurring cost may face budget scrutiny in Year 2+

TECHNICAL CHALLENGES

Privacy Impact Assessment (PIA) Expertise

Challenge: Conducting PIAs requires Privacy Officer to understand data flow architecture, processing risks, legal bases, and compliance safeguards. NorthStream has no PIA templates or process. Each PIA requires:

- 40–60 hours of Privacy Officer time
- Technical interviews with IT/product teams
- Risk assessment and safeguard documentation
- CAI registration (if high-risk)

Solution: Develop PIA template based on GDPR Article 35 + Law 25 guidance. Contract privacy law firm to review first 2–3 PIAs (CAD \$5K–10K each) to train Privacy Officer on process. After 3–4 PIAs, Privacy Officer becomes proficient.

Data Inventory & Classification

Challenge: Privacy Officer must maintain inventory of ALL NorthStream data:

- Employee records (HR, payroll, email)
- Customer data (Rewards app, CRM, marketing)
- Vendor data (supplier information, contracts)
- Operational data (sensors, telemetry, financials)

Each category must be classified (public/internal/confidential/restricted) with legal basis + location. NorthStream currently has no centralized data inventory.

Solution: Implement data catalog tool (Collibra, Informatica, Apache Atlas):

- Identify all data sources
- Map data flows
- Apply classification tags (GDPR sensitive, Law 25 indicator)
- Cost: CAD \$30K–50K (tool + 200 hours population)
- Timeline: 3–4 months

Breach Notification 24-Hour Reporting to CAI

Challenge: Quebec Law 25 requires CAI notification within 24 hours of breach awareness (faster than GDPR's 72 hours, PIPEDA's "without unreasonable delay"). NorthStream's current timeline is ~5 days. Compressing to 24 hours requires:

- Automated breach detection (IDS monitoring)
- Streamlined assessment process
- Pre-written notification template
- Privacy Officer on-call (24/7)

Solution:

- Deploy SIEM system (Splunk, ELK, Wazuh) with Quebec data breach detection rules
- Establish protocol: SIEM alert → CISO initiates assessment → If Quebec data involved → CAI notification within 2 hours
- Privacy Officer maintains CAI contact + pre-written template
- Cost: CAD \$25K–40K (SIEM + configuration)
- Timeline: 6–8 weeks

BUSINESS IMPACT

Operational Slowing – Feature Release Cycles

Impact: Privacy Officer oversight may slow product development:

- Every feature collecting personal data must undergo PIA before launch
- PIA adds 4–6 weeks to product roadmap
- Product teams perceive Privacy Officer as "gatekeeper"

Example: "Premium Location-Based Fuel Discounts" feature:

- Without PIA: 12 weeks launch
- With PIA: 16–18 weeks launch

Mitigation: Frame Privacy Officer as "product enabler" not "blocker." Conduct training showing how privacy controls (proper consent, encryption, access limits) REDUCE legal/reputational risk + enable market differentiation. Establish fast-track PIA process (2–3 weeks) for low-risk features.

Ongoing Budget Commitment

Impact: Privacy Officer represents ongoing cost center with no direct revenue:

- Year 1: CAD \$128K–215K
- Year 2+: CAD \$100K–150K annually

Finance team may question: "Why spend CAD \$120K on privacy when we could invest in customer acquisition?"

Mitigation: Quantify risk reduction:

- GDPR fine for non-compliance: EUR €8–15M (CAD \$12–23M)
- Quebec Law 25 fines: CAD \$100K per violation × 10+ violations = CAD \$1M+
- Breach notification costs: CAD \$500K–1M per major breach
- Privacy Officer cost (CAD \$120K) is 0.5–1% of breach/fine exposure = **100:1 ROI**

Prepare business case showing Privacy Officer as "insurance policy" preventing catastrophic risk.

Vendor/Stakeholder Expectations

Impact: International expansion increasingly requires Privacy Officer:

- EU customers ask: "Who is your DPO?" and "Provide GDPR documentation?"
- Quebec customers ask: "Are you compliant with Law 25?"
- Lack of Privacy Officer signals "we don't take privacy seriously" → customer churn
- Competitors without Privacy Officer are non-compliant; NorthStream's appointment becomes competitive differentiator

Mitigation: Use Privacy Officer appointment as marketing asset. Publish: "NorthStream appoints Chief Privacy Officer [Name] to ensure GDPR, PIPEDA, and Law 25 compliance." This reassures customers + differentiates from competitors.

PROPOSED SOLUTION: PHASED PRIVACY OFFICER IMPLEMENTATION

Rather than "all or nothing," recommend **3-phase implementation over 12 months** to manage risk and cost:

Phase 1 (Months 1–3): External Consultant Lead

- Engage external privacy law firm for part-time Privacy Officer services (CAD \$25K–35K annually)
- External consultant:
 - Leads PIA process for new systems
 - Drafts information security program
 - Handles CAI liaison (24-hour breach notifications)
 - Trains NorthStream staff
- CISO retains oversight; consultant reports to CISO
- **Cost:** CAD \$40K–55K (consultant + documentation/training)
- **Benefit:** Low cost; immediate compliance; time to recruit permanent hire
- **Risk:** Consultant is part-time; may not be available during urgent incidents

Phase 2 (Months 4–9): Hybrid Model – Consultant + Internal Coordinator

- Continue external consultant (part-time; CAD \$25K–35K annually)
- Hire internal "Privacy Compliance Coordinator" (CAD \$50K–60K salary):
 - Full-time NorthStream employee
 - Handles day-to-day PIA administration, breach incidents, training
 - Supports consultant on legal questions
 - Builds institutional knowledge of NorthStream's data flows
 - Not a full Privacy Officer but provides continuity
- **Cost:** CAD \$85K–105K total (coordinator + consultant)
- **Benefit:** Hybrid cost between part-time consultant (\$30K) and full Privacy Officer (\$120K); consultant focuses on strategy
- **Risk:** Coordinator must defer to consultant on complex legal matters

Phase 3 (Months 10–12): Full-Time Privacy Officer Transition

- Promote Privacy Compliance Coordinator to Privacy Officer with additional training:
 - Enroll in CIPP/C (Certified Information Privacy Professional – Canada)
 - External consultant provides mentorship (CAD \$10K–15K)
- Reduce consultant to advisory role only (CAD \$5K–10K annually)
- Full-time Privacy Officer salary: CAD \$90K–110K
- **Cost:** CAD \$100K–140K total (Privacy Officer + consultant advisory)
- **Benefit:** Permanent internal Privacy Officer; reduced external dependency; coordinator brings institutional knowledge
- **Timeline:** CIPP/C certification 6–12 months concurrent with Coordinator role

Total 12-Month Implementation Cost

Phase	Duration	Cost
Phase 1	Months 1–3	CAD \$40K–55K
Phase 2	Months 4–9	CAD \$85K–105K
Phase 3	Months 10–12	CAD \$100K–140K
TOTAL YEAR 1	12 months	CAD \$225K–300K

This is higher than Mapping 5 estimate (CAD \$128K–215K) because it includes full consultant + coordinator hybrid, but phased approach de-risks implementation and ensures compliance continuity.

Alternative Approach: Full-Time Privacy Officer from Day 1

If NorthStream prefers to avoid consultant dependency:

- Immediately hire full-time Privacy Officer (CAD \$90K–120K annually)
- External legal counsel support as needed (CAD \$10K–20K annually)
- **Cost:** CAD \$100K–140K Year 1
- **Benefit:** Faster compliance (Privacy Officer leads immediately)
- **Risk:** 3–6 month recruitment timeline; new hire ramp-up period; knowledge loss if Privacy Officer leaves

CONCLUSION

Control 5 (Privacy Officer & Information Security Program) is the hardest to implement because it requires ORGANIZATIONAL CHANGE rather than just technical implementation. However, the phased 3-phase approach (consultant → coordinator hybrid → permanent Privacy Officer) mitigates risk while ensuring Law 25 compliance.

Recommended Approach: Begin Phase 1 (external consultant) immediately (January 2026) to address urgent compliance gaps. Transition to Phase 2 (coordinator) by May 2026. Complete Phase 3 (permanent Privacy Officer) by December 2026.

This timeline ensures NorthStream is compliant with Quebec Law 25 Articles 14–18 while managing organizational and financial constraints.

APPENDIX: NIST CSF 2.0 FRAMEWORK OVERVIEW

NIST Cybersecurity Framework 2.0 consists of:

6 Functions:

1. **Govern (GV)** – Governance structures, risk management strategy, organizational roles
2. **Identify (ID)** – Understand organizational assets, data, and risks
3. **Protect (PR)** – Implement safeguards to mitigate risks
4. **Detect (DE)** – Identify cybersecurity incidents when they occur
5. **Respond (RS)** – Take action to address incidents and mitigate impact
6. **Recover (RC)** – Restore normal operations post-incident

23 Categories (e.g., PR.DS-01 "Data at Rest Protection"; RS.RP-01 "Response Planning")

210+ Subcategories (detailed control practices)

Priority Maturity Levels (18-Month Phase 1)

Function	Target Maturity	Rationale
Govern	Level 3 (Defined)	Establish governance early; Privacy Officer & CISO define policies
Identify	Level 2 (Repeatable)	Data inventory underway; classification framework established
Protect	Level 3 (Defined)	Critical for compliance (encryption, access control)
Detect	Level 2 (Repeatable)	Basic incident detection; SIEM planned
Respond	Level 3 (Defined)	Incident response procedures; 72-hour & 24-hour notification timelines
Recover	Level 1 (Initial)	Basic backup/recovery; enhanced in Year 2